

LetsDefend Alert - Event ID 125

Description

EventID: 125
Event Time: Sep, 30, 2022, 07:19 AM
Rule: SOC175 - PowerShell Found in Requested URL - Possible CVE-2022-41082 Exploitation
Level: Security Analyst
Hostname: Exchange Server 2
Destination IP Address: 172.16.20.8
Log Source: IIS
Source IP Address: 58.237.200.6
Request URL: /autodiscover/autodiscover.json?
@evil.com/owa/&Email=autodiscover/autodiscover.json%3f@evil.com&Protocol=XYZ
&FooProtocol=PowerShell
HTTP Method: GET
User-Agent: Mozilla/5.0 zgrab/0.x
Action: Blocked
Alert Trigger Reason: Request URL Contains PowerShell

0
/ 91
Community
Score -2

No security vendor flagged this IP address as malicious
58.237.200.6 (58.236.0.0/15)
AS 9318 (SK Broadband Co Ltd)
KR
Last Analysis Date
a moment ago
Reanalyze More

DETECTIONDETAILSRELATIONS**COMMUNITY** 7

[Join our Community](#) and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Voting details (4)

 PoladSamadov 2 months ago +1	 HARUN1907 2 months ago -1	 Dark_s 6 months ago -1
 Ngabers 1 year ago -1		

Comments (3)

**parthmaniar**
3 years ago
This IP was carrying out an SSH brute force attack on 09-08-2022. For more information or to report interesting/incorrect findings, give me a shoutout @parthmaniar on Twitter.

**PoisOnEy3**

Overview of ProxyNotShell (CVE-2022-41040 & CVE-2022-41082)

The CVE-2022-41082 together with CVE-2022-41040 form the vulnerability chain known as **ProxyNotShell**. The chain allows attackers to exploit Microsoft Exchange Server to achieve Remote Code Execution (RCE). Due to its flexibility, both detection and mitigation can be challenging.

A detailed description of **ProxyNotShell** is available here:

<https://www.zerodayinitiative.com/blog/2022/11/14/control-your-types-or-get-pwned-remote-code-execution-in-exchange-powershell-backend>

A more concise explanation can be found here:

<https://www.picussecurity.com/resource/blog/proxynotshellcve-2022-41040-and-cve-2022-41082-exploits-explained>

In this investigation, we focus on the first stage of **ProxyNotShell** - CVE-2022-41040, which is conceptually similar to CVE-2021-34473. CVE-2021-34473 allowed unauthenticated SSRF, while CVE-2022-41040 restricts SSRF to authenticated users. This stage is commonly observed in logs as crafted Autodiscover requests.

To better understand the attack, consider the following snippet from the **Metasploit** Microsoft Exchange ProxyNotShell RCE module, which demonstrates how attackers craft malicious Autodiscover requests.

The use of `/autodiscover/autodiscover.json` reflects the SSRF entry point, while references to `powershell` indicate attempts to access the Exchange PowerShell backend. This behaviour is consistent with the suspicious URLs observed in the logs.

```
if uri =~ /powershell/i && datastore['EemsBypass'] == 'IBM037v1'
  uri = "/Autodiscover/autodiscover.json?#{ibm037(@ssrf_email + uri +
  '?')}&#{ibm037('Email')}=#{ibm037('Autodiscover/autodiscover.json?' +
  @ssrf_email)}"
  opts[:headers] = {
    'X-Up-Devcap-Post-Charset' => 'IBM037',
    'User-Agent' => "UP #{datastore['UserAgent']}"
  }
else
  uri = "/Autodiscover/autodiscover.json?#{@ssrf_email + uri}?
  &Email=Autodiscover/autodiscover.json?#{@ssrf_email}"
end
```

Info

`%3f` is the URL-encoded representation of `?`, commonly used to bypass input validation

Info

IBM037 is an EBCDIC character encoding (used in legacy IBM systems).

The exploit encodes parts of the request using IBM037 - this can **bypass security filters** that expect standard ASCII/UTF-8

Investigation

Suspicious User-Agent

Before we start to dig in the logs, it is worth taking a closer look at the details of the alerts. We can see a non-standard `User-Agent` associated with scanning tools:

```
User-Agent: Mozilla/5.0 zgrab/0.x
```

It points at the `zgrab` scanner and indicates automated scanning and reconnaissance.

<https://github.com/zmap/zgrab2/blob/master/modules/http/scanner.go#L54>

```
type Flags struct {  
    ...  
    UserAgent      string `long:"user-agent" default:"Mozilla/5.0  
zgrab/0.x" description:"Set a custom user agent"`  
    ...  
}
```

Quote

ZGrab is a fast, modular application-layer network scanner designed for completing large Internet-wide surveys. ZGrab is built to work with ZMap (...).

<https://github.com/zmap/zgrab2/tree/master>

Network Logs

The screenshot shows a network log management interface. On the left is a sidebar with navigation links: Log Management, Case Management, Endpoint Security, Email Security, Threat Intel, and Sandbox. The main area is titled 'New Search' and displays a search query: 'Source Address equals "58.237.200.6" and Destination Address equals "172.16.20.8"'. Below the query, it indicates '3 events (before Sep, 30, 2022, 07:19 AM UTC)'. A table of results is shown with columns for 'Event' and 'Type'. The table contains three entries, all of which are GET requests to port 443, blocked by the device. The source addresses are all 58.237.200.6, and the destination addresses are all 172.16.20.8. The source ports are 45957, 35783, and 35773. The raw log data is also visible in the table.

Event	Type
[Sep, 30, 2022, 07:17 AM] source_address=58.237.200.6 source_port=45957 des...	GET
[Sep, 30, 2022, 07:18 AM] source_address=58.237.200.6 source_port=35783 des...	GET
[Sep, 30, 2022, 07:19 AM] source_address=58.237.200.6 source_port=35773 des...	GET

Three Exchange logs were identified with source address 58.237.200.6 and destination address 172.16.20.8

Time range: Sep, 30, 2022, 07:17 AM - 07:19 AM

All of them are GET requests to port 443 and all of them were blocked (Device Action: Blocked).

The requests came from high ephemeral source ports (45957, 35783, 35773).

Logged URLs:

- /autodiscover/autodiscover.json
- /autodiscover/autodiscover.json?@evil.com/ews/exchange.asmx?&Email=autodiscover/autodiscover.json%3f@evil.com
- /autodiscover/autodiscover.json?@evil.com/owa/&Email=autodiscover/autodiscover.json%3f@evil.com&Protocol=XYZ&FooProtocol=Powershell

The presence of FooProtocol=Powershell is a strong indicator of an attempt to access the Exchange PowerShell backend (CVE-2022-41082 stage).

These requests match the SSRF pattern used in CVE-2022-41040 exploitation attempts.

Source IP Analysis

Source IP: 58.237.200.6

ASN: 9318

Country: KR

VirusTotal

<https://www.virustotal.com/gui/ip-address/58.237.200.6>

No vendor detections, Community score: -2, with comments indicating SSH brute-force activity

Important

If the report is outdated, the **Reanalyze** feature can be used to refresh the results.

Attackers may use IP addresses with little or no prior reputation, relying on outdated threat intelligence to evade detection.

AbuseIPDB

<https://www.abuseipdb.com/check/58.237.200.6>

Reported 608 times - port scan, ssh, brute-force

LetsDefend Threat Intel

Not found

Endpoint Analysis

Destination IP: 172.16.20.8

Hostname: Exchange Server 2

Primary User: ExchangeAdmin

Client/Server: Server

Last Login: Sep, 22, 2022, 06:25 PM

The attacker requests were blocked according to the Exchange logs.

There is no evidence of successful exploitation or post-compromise activity on the endpoint.

No escalation or isolation is required.

Hostname: Exchange Server 2

Domain: LetsDefend

IP Address: 172.16.20.8

Bit Level: 64

OS: Windows Server 2019

Primary User: ExchangeAdmin

Client/Server: Server

Last Login: Sep, 22, 2022, 06:25 PM

Containment: ☐

Processes 5

Network Action 13

Terminal History 2

Browser History 22

Results: 10

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
▼ No Event Time	No Process ID	Chrome.exe	—	c:/program files (x86)/googl...
▼ No Event Time	No Process ID	ccsvchst.exe	—	c:/program files (x86)/syma...
▼ No Event Time	No Process ID	notepad.exe	—	c:/windows/system32/notep...
▼ No Event Time	No Process ID	powershell.exe	—	Get-ChildItem Desktop

Find More Writeups Here

 Info

<https://robjar101.gitlab.io/secstash/>